APPLICATION SECURITY REVIEW

Intake Questionnaire

Acme Leave Tracker

Submitted Ticket ASR-2026-038, received 2026-08-25

Complete this form to request an application security review. The AppSec team uses it to set the review depth and to schedule testing. Answers below were completed by the requester (shown in blue italics).

A. Request details

A1 Application name and version	*Acme Leave Tracker 1.4.0*
A2 Business owner / product owner	*Priya Nair, HR Operations Manager*
A3 Technical lead	*Tomas Lindqvist*
A4 Business unit and cost centre	*People Operations, cost centre 2210*
A5 Reason for review (new release, major change, annual, audit)	*New application ahead of production go-live*
A6 Target go-live date	*2026-10-01*

B. Application overview

B1 What does the application do, and who uses it?	*Employees request and view time off; HR administrators approve and export. About 1,400 employees.*
B2 Internet-facing, internal only, or partner access?	*Internal only (corporate network and VPN)*
B3 Application tier (business criticality)	*Tier 2 (important)*
B4 Languages, frameworks and runtime	*Python 3.12 service, PostgreSQL, Docker on ECS*

C. Data

C1 Most sensitive data processed or stored	*Employee names, leave dates, leave type and free-text notes that may include health information*
C2 Data classification	*Confidential*
C3 Regulatory scope (PCI DSS, GDPR, SOX, HIPAA, none)	*GDPR (special-category data possible)*
C4 Data retention and deletion approach	*Leave records kept 6 years after employment ends; deletion job planned*

D. Architecture and hosting

D1 Hosting platform and regions	*AWS eu-west-1: ECS Fargate, RDS PostgreSQL, S3*
D2 Datastores and encryption at rest	*RDS and S3 encrypted with KMS*
D3 Inbound and outbound integrations	*Nightly HRIS employee feed (inbound file). No outbound integrations.*
D4 Secrets management	*AWS Secrets Manager for database credentials*

E. Identity and access

E1 How are users authenticated?	*Corporate SSO (OIDC); bearer token to the API*
E2 How is authorisation enforced (roles, ownership checks)?	*Role claim from SSO (employee, hr_admin); owner filter on search*
E3 Privileged / admin functions	*HR bulk export (hr_admin role only)*

F. Delivery pipeline

F1 Source control and branch protection	*GitHub; branch protection with two reviewers*
F2 Automated security checks in CI	*Demo pipeline: secrets, SAST, SCA, IaC, container, DAST*
F3 Open-source dependency management	*Dependabot enabled*
F4 Previous penetration tests or reviews	*None; this is the first review*

G. Declaration

G1 Requester	*Tomas Lindqvist, Technical Lead*
G2 Date submitted	*2026-08-25*

AppSec triage (completed by reviewer)

Assigned tier	Tier 2 (important)
Review depth	Standard review: threat model, targeted code review, pipeline results
Triaged by	AppSec Review Team (demo)
Report ticket	ASR-2026-038